step: 1.3

plan: ../PLAN-MASTER.md

agent: senior-developer

status: done

completed_at: 2026-11-02T21:25:00+07:00

deps: [1.2]

# STEP 1.3 — Rate-Limiter, An toàn Upload, Vá `/desktop` 404, Atomic `Task.number` & `/verify-pr` (`G0-4` & `G0-6a`)

## Input nhận

- Handoff Payload từ `STEP-1.2`.

## Nhiệm vụ

1. Tạo module `src/lib/rate-limit.ts` (in-memory token bucket / sliding window per IP):

- `/api/auth/login`: tối đa 10 requests / phút.
- `/api/tickets/public` & `/api/tickets` (POST): tối đa 5 requests / phút.
- `/api/upload`: tối đa 20 requests / phút.

2. Củng cố an toàn cho `src/app/api/upload/route.ts`:

- Bắt buộc người dùng phải đăng nhập hợp lệ trước khi upload file (`getSessionUser(req)`).
- Chặn tuyệt đối các tệp thực thi web nguy hiểm: `.html, .htm, .svg, .js, .mjs, .cjs, .xhtml, .xml, .php, .exe, .bat, .cmd, .ps1, .sh, .vbs, .dll, .com, .scr, .msi, .jsp, .asp, .aspx`.
- Kiểm tra magic bytes của các tệp ảnh phổ biến (PNG, JPEG/JPG, GIF, WEBP).
- Tên tệp lưu trữ sinh bằng UUID ngẫu nhiên, chống path traversal.
- Cấu hình response headers `X-Content-Type-Options: nosniff`, `Content-Security-Policy: default-src 'none'; sandbox` và `X-Frame-Options: DENY` cho thư mục `/uploads/*` trong `next.config.ts`.

3. Bảo vệ Zalo Webhook (`src/app/api/integrations/zalo/webhook/route.ts`): Bắt buộc kiểm tra token / `oaSecretKey` trước khi tiếp nhận payload.
4. Khắc phục lỗi 404 trên `/desktop`:

- Sửa route gọi trong `src/app/desktop/page.tsx`: đổi `PATCH /api/tasks/${taskId}` thành route chuẩn `PATCH /api/projects/${projectId}/tasks/${taskId}`.
- Xử lý đúng cấu trúc JSON response trả về khi tạo task mới (`data.task || data`).
- Tạo thêm router alias `src/app/api/tasks/[taskId]/route.ts` xử lý GET, PATCH, DELETE đảm bảo không còn lỗi 404 từ bất kỳ client nào.

5. Đảm bảo tính nguyên tử (Atomic) khi sinh `Task.number` trong `src/app/api/projects/[projectId]/tasks/route.ts`: Bọc câu lệnh tìm `max(number)` và `task.create` bên trong `prisma.$transaction` có cơ chế retry tối đa 3 lần khi gặp mã lỗi `P2002` (Unique constraint failed on `projectId_number`).
6. Tạo endpoint kiểm tra sức khỏe hệ thống `src/app/api/health/route.ts` (`GET` trả về status, kết nối DB PostgreSQL 17 `SELECT 1`, uptime).
7. Cập nhật `code-graph/CODE-GRAPH.md` phản ánh đúng PostgreSQL 17 và các module mới theo Rule R3. Xuất DOCX và PDF.
8. Chạy `/verify-pr` kiểm tra build và lint, chạy bộ test tự động `scripts/test_step_1_3.ts` đạt 100% PASS (20/20 tests).

## Definition of Done

- [x] Gửi request login sai quá 10 lần bị trả về `429 Too Many Requests`.
- [x] Upload file `.html` hoặc `.svg` bị từ chối ngay lập tức (HTTP 400).
- [x] Giao diện `/desktop` tạo task và cập nhật trạng thái hoạt động trơn tru (HTTP 200), không còn lỗi 404.
- [x] Bắn nhiều request tạo task đồng thời không bị trùng mã hoặc crash do `P2002`.
- [x] `/api/health` phản hồi `200 { status: "ok", db: "connected" }`.
- [x] `code-graph/CODE-GRAPH.md` được cập nhật, xuất file PDF/DOCX thành công.
- [x] `/verify-pr` toàn bộ PASS.

## Đã làm

1. **Module Rate Limiting (`src/lib/rate-limit.ts`)**:

- Xây dựng sliding-window in-memory rate limiter per-IP có hàm tự động dọn dẹp bộ nhớ định kỳ (`cleanupExpiredRecords`).
- Tích hợp rate limit: Login (10 req/min), Tickets public & create (5 req/min), Upload (20 req/min). Trả về chuẩn HTTP 429 kèm `Retry-After`, `X-RateLimit-*`.

2. **An toàn Tải Lên Tệp Tin (`src/app/api/upload/route.ts` & `next.config.ts`)**:

- Xác thực người dùng đăng nhập qua session cookie hoặc Bearer Token trước khi cho phép tải lên.
- Chặn tuyệt đối danh sách 21 phần mở rộng nguy hiểm.
- Xác thực Magic Bytes nhị phân cho các định dạng ảnh PNG (`\x89PNG`), JPEG (`\xFF\xD8\xFF`), GIF (`GIF8`), WEBP (`RIFF...WEBP`).
- Lưu tệp tin bằng tên ngẫu nhiên UUID `${Date.now()}-${randomUUID()}${ext}`, triệt tiêu hoàn toàn rủi ro path traversal.
- Bổ sung cấu hình security headers trong `next.config.ts` cho đường dẫn `/uploads/:path*` (`X-Content-Type-Options: nosniff`, `Content-Security-Policy: default-src 'none'; sandbox`, `X-Frame-Options: DENY`).

3. **Bảo vệ Zalo Webhook (`src/app/api/integrations/zalo/webhook/route.ts`)**:

- Kiểm tra chặt chẽ secret key cấu hình (`cfg.oaSecretKey` hoặc `process.env.ZALO_WEBHOOK_SECRET`). Từ chối `403` nếu hệ thống chưa kích hoạt/cấu hình secret.
- Xác thực chữ ký `x-zevent-signature` hoặc secret header/query. Từ chối `401` nếu chữ ký sai hoặc không hợp lệ.

4. **Khắc phục lỗi 404 và dữ liệu trên `/desktop`**:

- Cập nhật `src/app/desktop/page.tsx`: chuyển lệnh PATCH task sang route chuẩn `/api/projects/${projectId}/tasks/${taskId}`.
- Trích xuất dữ liệu task tạo mới từ `resData.task || resData` gán trực tiếp vào React state, không còn lỗi giao diện hay phải F5.
- Tạo thêm router alias `src/app/api/tasks/[taskId]/route.ts` hỗ trợ GET, PATCH, DELETE tra cứu theo taskId và phân quyền dự án, chống triệt để mọi lỗi 404 từ client.

5. **Đảm bảo tính Nguyên tử (Atomic) khi sinh `Task.number`**:

- Cập nhật `src/app/api/projects/[projectId]/tasks/route.ts`: bọc câu lệnh lấy `lastTask.number` và `tx.task.create` trong `prisma.$transaction`.
- Bổ sung vòng lặp retry tối đa 3 lần kèm exponential/jitter backoff khi bắt được mã lỗi Prisma `P2002` (Unique constraint on `projectId_number`).

6. **Endpoint Kiểm Tra Sức Khỏe (`src/app/api/health/route.ts`)**:

- Endpoint `GET /api/health` thực thi truy vấn nhẹ PostgreSQL 17 (`SELECT 1`), trả về 200 `{ status: "ok", db: "connected", timestamp, uptime }` (hoặc 503 degraded nếu lỗi kết nối).

7. **Cập nhật Bản Đồ Codebase (`code-graph/CODE-GRAPH.md`)**:

- Cập nhật bản đồ codebase Version 2.3 phản ánh CSDL PostgreSQL 17 và 6 module bảo mật mới.
- Biên dịch thành công ra file `code-graph/CODE-GRAPH.docx` và `code-graph/CODE-GRAPH.pdf`.

8. **Kiểm thử tự động & Xác minh `/verify-pr`**:

- Xây dựng kịch bản kiểm thử toàn diện `scripts/test_step_1_3.ts` kiểm chứng 5 khối chức năng. Chạy đạt kết quả **20/20 TESTS PASS (100%)**.
- Kiểm tra kiểu dữ liệu TypeScript với `npx tsc --noEmit` đạt **0 errors**.

## Artifact

- `src/lib/rate-limit.ts`
- `src/app/api/health/route.ts`
- `src/app/api/tasks/[taskId]/route.ts`
- `scripts/test_step_1_3.ts`
- `code-graph/CODE-GRAPH.md`
- `code-graph/CODE-GRAPH.docx`
- `code-graph/CODE-GRAPH.pdf`
- Modified: `src/app/api/auth/login/route.ts`, `src/app/api/tickets/public/route.ts`, `src/app/api/tickets/route.ts`, `src/app/api/upload/route.ts`, `src/app/api/integrations/zalo/webhook/route.ts`, `src/app/desktop/page.tsx`, `src/app/api/projects/[projectId]/tasks/route.ts`, `next.config.ts`.

## Quyết định quan trọng

- Bổ sung cả router alias `src/app/api/tasks/[taskId]/route.ts` song song với việc sửa link trong `/desktop`: Đảm bảo backward compatibility cho toàn bộ các màn hình cũ hoặc client bên ngoài gọi task trực tiếp theo taskId.

- Dùng `getSessionUser(req)` truyền request context để hỗ trợ cả cookie lẫn Header Bearer Token RFC 6750 cho Mobile App.
- Cơ chế retry concurrency cho `Task.number` sử dụng ngẫu nhiên backoff 20-70ms giúp các transaction đồng thời không bị retry trùng thời điểm.

## Handoff Payload — bước sau đọc phần này (chỉ phần này, không cần đọc "Đã làm")

- do_not_redo:
  - Toàn bộ Phase 1 (Bước 1.1, 1.2, 1.3) đã hoàn thành 100%, TypeScript không lỗi, test suite 20/20 PASS.
  - Không cần sửa đổi lại sanitizeHtml, crypto-secrets.ts, cơ chế mã hóa enc:v1:..., rate-limiter và cookie config.
- watch_out:
  - Khi chạy các script trên Windows cần kèm nạp PATH: `$env:PATH = "C:\Users\Admin\node\PFiles64\nodejs;$env:PATH"`.
  - Khi viết code API upload cần luôn truyền `req` vào `getSessionUser(req)` để hỗ trợ Bearer token và cookie.
- next_inputs:
  - Chuyển giao toàn bộ kết quả Phase 1 sang **Phase 2 (Bước 2.1)**: TECH LEAD thực hiện Code Review và Security Review toàn diện trước khi bàn giao cho QA Engineer.

## Commit

- Hash:
- Đã push:

---

**Status icons:** ☐ Todo | 🔄 In Progress | ✅ Done | 🛑 Blocked | ⏭ Skipped